PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Automatisation ACME

03-340 ANSSI - Automatisation de la gestion des certificats avec ACME — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. L'automatisation vise à limiter le risque d'indisponibilité des applicatifs métiers dû à un défaut de renouvellement.
2. Le client ACME doit utiliser un compte de service dédié sans privilèges super-utilisateur.
3. Le programme Certificate Transparency permet de détecter l'émission illégitime de certificats par une autre autorité de certification pour un domaine autorisé du demandeur.

Synthèse de l'automatisation ACME

Notion	À retenir
Objectifs automatisation	Limiter le risque d'**indisponibilité** des applicatifs métiers dû à un défaut de **renouvellement** (durée de vie des certificats en raccourcissement).
Changement rôles/architecture	Fournisseur : **AC intermédiaire**, **serveur ACME**, **comptes externes**. Demandeur : délivrance **décentralisée** via **client ACME** au plus près du serveur web.
Risques fournisseur	Compromission **autorité d'enregistrement**, **serveur ACME**, usurpation **compte externe** ou détournement de trafic par **attaque BGP**.
Risques demandeur	Compromission **clé privée compte ACME**, **serveur/client ACME** ou **éléments de binding** du compte externe.

Recommandations concernant le fournisseur de certificats

Notion	À retenir
Compte externe administration	Créé avec **authentification multifacteur** (création/mise à jour). Paramètres : domaines autorisés (validation humaine), validité, comptes ACME associés, régénérations clé secrète. Vérification **DNS CAA** obligatoire.
Compromission et renouvellement	Validité max **3 ans**. Éléments de binding renouvelables sur demande. En cas de compromission : désactivation, nouveau compte et réassociation des comptes non suspects via **authentification multifacteur**.
Compte ACME et binding	Associé à **un unique compte externe**. Recommandation : suspension possible si bi-clé suspecte. MAC (ex: `HMAC-SHA256`) conforme au guide cryptographique. MAC key protégée (ex: `TLS` ou conteneur chiffré).
Protocole ACME et certificats	Conformité **RFC 8555**. Rejet domaines non autorisés, validation multi-points, limite échecs (ex: **5/compte/heure**). Nouveau bi-clé par émission. **Certificats wildcard interdits**. Validité max **90 jours**.
AC et gouvernance	Certificat **X509 intermédiaire** dédié et infrastructure cloisonnée. Écritures base de données limitées à l'autorité d'enregistrement. Enregistrement **Certificate Transparency** et proposition d'un service **staging** (certificats identifiables).

Recommandations concernant le client ACME

Notion	À retenir
Fonctionnalités et choix	Conforme **RFC 8555** ; idéalement **certifié ou qualifié par l'ANSSI** ; limiter la **diversité logicielle** pour faciliter le maintien en conditions de sécurité.
Mise en œuvre et privilèges	Utiliser un **compte de service dédié** (sans privilèges super-utilisateur) ; accès en **lecture seule** pour les services (ex: serveur web) ; accès aux **seuls répertoires nécessaires** pour les défis.
Installation et clés	Interface protégée par **authentification multifacteur** ; renouvellement aux **deux tiers** de la validité (≈ 60 j pour 90 j) ; **tests en staging** ; supprimer la **clé secrète** du compte externe après association.

Comparaison des défis, architectures et risques

Notion	À retenir
Types de défis	**HTTP-01** (facile, preuve faible, risque téléversement), **DNS-01** (complexe, preuve forte, impact DNS), **TLS-ALPN-01** (facile, nécessite contrôle pile TLS, support limité).
Architectures recommandées	Plusieurs clients ACME **cloisonnés** (sous-ensemble de domaines, authentifiants distincts). Variantes : **compte externe par client** (impact limité) ou **compte externe unique + compte ACME dédié par client** (remédiation lourde).
Architectures non recommandées	Gestion sur **unique client**, **unique compte externe** et **unique compte ACME** (impact global). Ou répartition sur plusieurs clients pouvant **tous résoudre tous les domaines** avec comptes uniques partagés.

Pièges et confusions

⚠ Croire que les éléments de binding, MAC key et KeyID protègent contre un attaquant capable de résoudre un défi ACME.
⚠ Exécuter le client ACME avec les privilèges de super-utilisateur.
⚠ Utiliser des certificats wildcard.
⚠ Confondre la détection d'une émission illégitime par une autre AC avec la protection offerte par le binding.

Sigles et définitions

AC	autorité d'enregistrement, la base de données associée et le service de génération de certificats du fournisseur de certificats
AC publique ACME	AC qui automatise la délivrance de certificats via le protocole ACME et dont l'AC racine est présente dans les magasins de confiance des navigateurs
AC interne ACME	AC non reconnue publiquement dont l'AC racine nécessite un ajout explicite dans les magasins de confiance
Compte externe d'administration ACME	sert à limiter et contrôler les actions des comptes ACME associés
Binding (EAB)	mécanisme associant un compte ACME à un compte externe d'administration ACME
Défi ACME	permet au demandeur de certificat de prouver sa possession du nom de domaine visé
Certificat wildcard	certificat valide pour tous les sous-domaines d'un domaine, de la forme étoile point domaine point extension
Certificate Transparency (CT)	ensemble de registres publics listant les certificats X509 émis

Auto-test

1. Quelle est la validité maximale recommandée pour un certificat via le protocole ACME ?
2. Quels sont les trois types de défis ACME possibles ?
3. Que faire en cas de compromission d'un compte externe ?
4. À quel moment faut-il effectuer le renouvellement ?
5. Quel mécanisme permet de surveiller l'apparition de certificats illégitimes ?

Réponses : **1.** 90 jours · **2.** HTTP-01, DNS-01 et TLS-ALPN-01 · **3.** Désactivation, nouveau compte et réassociation des comptes non suspects via authentification multifacteur · **4.** Aux deux tiers de la validité · **5.** Le programme Certificate Transparency

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.